

Configurazione e Cracking dell'Autenticazione di Servizi di Rete: un Caso di Studio su SSH e FTP mediante Hydra

Corso: Laboratorio di Cybersecurity / Ethical Hacking **Ambiente di prova:** Macchina virtuale Kali Linux (indirizzo IP privato 192.168.1.10), rete di laboratorio isolata **Strumenti impiegati:** OpenSSH Server, vsftpd, THC-Hydra v9.7, SecLists

Indice

1. Introduzione
 2. Obiettivi dell'Esercizio
 3. Ambiente di Laboratorio e Note Etiche
 4. Metodologia
 5. Fase 1 – Configurazione e Cracking del Servizio SSH
 6. Fase 2 – Configurazione e Cracking del Servizio FTP
 7. Analisi Comparata dei Risultati
 8. Analisi dei Rischi e Contromisure
 9. Verifica di Aderenza agli Obiettivi Didattici
 10. Considerazioni Finali e Lezioni Apprese
-

1. Introduzione

La sicurezza dell'autenticazione costituisce uno dei pilastri fondamentali della protezione dei sistemi informatici esposti in rete. Servizi ampiamente diffusi come SSH (*Secure Shell*) e FTP (*File Transfer Protocol*) sono, per loro natura, punti di accesso privilegiati a un sistema, e la robustezza delle credenziali che ne regolano l'accesso rappresenta pertanto un fattore critico per la sicurezza complessiva dell'infrastruttura. La presente esercitazione si colloca nell'ambito delle attività di *Vulnerability Assessment* e *Penetration Testing* (VAPT), disciplina che, se condotta secondo un codice etico rigoroso e in ambienti autorizzati, consente di individuare preventivamente le debolezze di un sistema prima che possano essere sfruttate da un attore malevolo.

Nel corso dell'esercitazione è stato utilizzato **Hydra** (THC-Hydra), uno strumento open source di *password auditing* ampiamente adottato nella comunità della sicurezza informatica per la verifica automatizzata della robustezza delle credenziali di autenticazione su una vasta gamma di protocolli e servizi di rete. Si precisa che l'intero esercizio è stato condotto in un ambiente di laboratorio virtualizzato, isolato dalla rete pubblica, contro un sistema (Kali Linux) e utenti (**test_user**) appositamente creati dallo scrivente per le sole finalità dell'esercitazione, in piena conformità con i principi dell'*ethical hacking* e nel pieno rispetto della normativa vigente in materia di accesso abusivo a sistemi informatici.

2. Obiettivi dell'Esercizio

Come indicato nella consegna fornita (documento *README.md* dell'esercitazione), l'attività persegue un duplice obiettivo didattico:

1. **Acquisire familiarità con lo strumento Hydra** per la verifica della robustezza dei meccanismi di autenticazione dei servizi di rete, attraverso attacchi a dizionario condotti in ambiente controllato.
2. **Consolidare le competenze di configurazione dei servizi stessi**, poiché — come esplicitamente indicato nella traccia — «la configurazione dei servizi costituisce essa stessa una parte integrante dell'esercizio».

L'esercizio si è sviluppato secondo due fasi distinte:

- una **prima fase guidata**, relativa alla configurazione del servizio SSH e alla conseguente sessione di *cracking* dell'autenticazione con Hydra;
- una **seconda fase autonoma**, nella quale è stato lasciato allo studente il compito di scegliere e configurare un ulteriore servizio di rete tra quelli suggeriti (FTP, RDP, Telnet, autenticazione HTTP), per poi sottoporre l'autenticazione a un analogo test di robustezza. È stato scelto il servizio **FTP**, tramite **vsftpd**, secondo l'indicazione consigliata nella traccia.

3. Ambiente di Laboratorio e Note Etiche

L'intera attività è stata condotta all'interno di un ambiente di laboratorio didattico, isolato dalla rete pubblica, avente le seguenti caratteristiche:

Parametro	Valore
Sistema operativo target/attaccante	Kali Linux 2026.3 (kernel 7.0.12-2kali1)
Indirizzo IP della macchina bersaglio	192.168.1.10 (rete privata di laboratorio)
Utente di test creato	<code>test_user</code>
Servizi oggetto dell'esercizio	SSH (porta 22), FTP/vsftpd (porta 21)
Strumento di auditing	THC-Hydra v9.7
Wordlist utilizzate	File personalizzati (<code>user.txt</code> , <code>password.txt</code>) e liste della suite SecLists

Si sottolinea, ai fini della piena trasparenza metodologica e in ottemperanza ai principi deontologici dell'*ethical hacking*, che:

- la macchina bersaglio è la medesima macchina virtuale utilizzata come postazione di attacco (topologia *self-contained*), configurata e amministrata dallo scrivente;
- l'utente `test_user`, oggetto dell'attività di cracking, è stato appositamente creato per l'esercizio, con una password nota (`testpass`) impostata consapevolmente dallo scrivente stesso;

4. Metodologia

La metodologia seguita ricalca un tipico ciclo di *Vulnerability Assessment* su servizi di autenticazione, articolato nelle seguenti fasi operative, ripetute per ciascuno dei due servizi analizzati:

1. **Installazione e attivazione del servizio** tramite i rispettivi gestori di pacchetti e `systemd/service`.
2. **Verifica dello stato del servizio** (`service <nome> status`), al fine di accertarne l'effettiva operatività e il corretto binding sulla porta prevista.
3. **Creazione di un'utenza di test** con credenziali note, funzionale alla validazione del funzionamento dell'attacco prima di procedere a scenari black-box.
4. **Verifica manuale dell'accesso** al servizio con le credenziali configurate, propedeutica alla successiva fase di auditing automatizzato.
5. **Esecuzione di Hydra** in modalità *single-credential* (opzioni `-l/-p`), per confermare la correttezza della sintassi e del bersaglio.
6. **Esecuzione di Hydra in modalità dizionario** (opzioni `-L/-P`), dapprima con wordlist di dimensioni contenute create manualmente, quindi con liste più estese tratte dalla suite SecLists.
7. **Osservazione e analisi delle prestazioni** dell'attacco al variare del grado di parallelismo (opzione `-t`), con relativa taratura empirica dei parametri per bilanciare velocità di esecuzione e stabilità del servizio bersaglio.
8. **Raccolta delle evidenze** (output testuale, screenshot) e analisi critica dei risultati.

```
(kali㉿kali)-[~]
└─$ sudo service ssh start

(kali㉿kali)-[~]
└─$ sudo service ssh status
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-07-17 10:51:43 CEST; 9s ago
 Invocation: bcf989e7f43b43268284ede9ba42e536
    Docs: man:sshd(8)
          man:sshd_config(5)
   Process: 17504 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 17515 (sshd)
    Tasks: 1 (limit: 2130)
   Memory: 2.5M (peak: 2.8M)
      CPU: 12ms
   CGroup: /system.slice/ssh.service
           └─17515 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

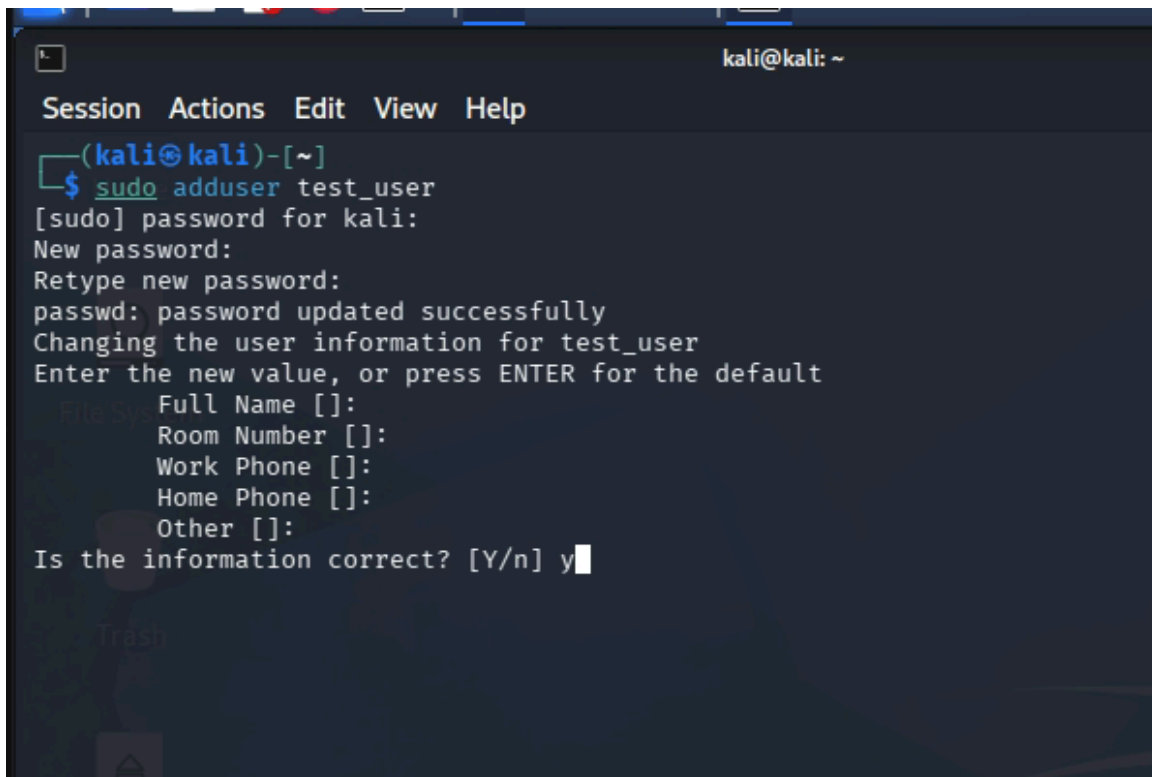
Jul 17 10:51:43 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server ...
Jul 17 10:51:43 kali sshd[17515]: Server listening on 0.0.0.0 port 22.
Jul 17 10:51:43 kali sshd[17515]: Server listening on :: port 22.
Jul 17 10:51:43 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.

(kali㉿kali)-[~]
└─$ █
```

5. Fase 1 – Configurazione e Cracking del Servizio SSH

5.1 Creazione dell'utenza di test

In conformità con la traccia guidata, è stata creata sulla macchina Kali Linux una nuova utenza denominata `test_user` mediante il comando `sudo adduser test_user`, impostando la password `testpass` e lasciando vuoti i campi anagrafici opzionali (Nome completo, Numero di stanza, Telefono ufficio, Telefono abitazione, Altro).



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo adduser test_user  
[sudo] password for kali:  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for test_user  
Enter the new value, or press ENTER for the default  
Full Name []:  
Room Number []:  
Work Phone []:  
Home Phone []:  
Other []:  
Is the information correct? [Y/n] y
```

La procedura si è conclusa correttamente, come attestato dal messaggio `passwd: password updated successfully` e dalla conferma dei dati inseriti (`Is the information correct? [Y/n] y`).

5.2 Attivazione e verifica del servizio SSH

Il servizio SSH è stato attivato mediante il comando `sudo service ssh start`. La successiva verifica dello stato (`sudo service ssh status`) ha confermato l'effettiva operatività del demone `sshd`, in ascolto sia in IPv4 (`0.0.0.0:22`) sia in IPv6 (`:::22`).

```
(kali㉿kali)-[~]
$ sudo service ssh start

(kali㉿kali)-[~]
$ sudo service ssh status
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-07-17 10:51:43 CEST; 9s ago
 Invocation: bcf989e7f43b43268284ede9ba42e536
    Docs: man:sshd(8)
          man:sshd_config(5)
   Process: 17504 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
    Main PID: 17515 (sshd)
       Tasks: 1 (limit: 2130)
      Memory: 2.5M (peak: 2.8M)
         CPU: 12ms
    CGroup: /system.slice/ssh.service
            └─17515 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jul 17 10:51:43 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server ...
Jul 17 10:51:43 kali sshd[17515]: Server listening on 0.0.0.0 port 22.
Jul 17 10:51:43 kali sshd[17515]: Server listening on :: port 22.
Jul 17 10:51:43 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.

(kali㉿kali)-[~]
$
```

Si rileva, dall'output riportato in Figura 2, che il servizio, pur avviato manualmente, risultava configurato come `disabled` a livello di preset di sistema — circostanza coerente con una configurazione di base non persistente al riavvio, tipica di un ambiente di laboratorio temporaneo.

5.3 Test con credenziali note (modalità single-target)

In prima battuta, conoscendo a priori username e password dell'utenza di test, è stato eseguito Hydra in modalità a credenziale singola (switch minuscoli `-l/-p`), secondo la sintassi suggerita dalla traccia:

```
hydra -l test_user -p testpass 192.168.1.10 ssh -t 4 -V
```

L'attacco ha individuato correttamente la coppia di credenziali valide in un unico tentativo, con esito riportato dalla riga [22][ssh] host: 192.168.1.10 login: test_user password: testpass, e completamento dell'operazione in circa un secondo.

```
(test_user@kali)~$ hydra -l test_user -p testpass 192.168.1.10 ssh -t 4 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics any way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 11:14:26
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ssh://192.168.1.10:22/
[ATTACK!] target 192.168.1.10 - login "test_user" - pass "testpass" - 1 of 1 [child 0] (0/0)
[22][ssh] host: 192.168.1.10 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 11:14:27

(test_user@kali)~$
```

5.4 Attacco a dizionario con wordlist personalizzata

Superata la fase di validazione sintattica, si è proceduto a un attacco a dizionario mediante gli switch maiuscoli **-L/-P**, utilizzando due file di testo personalizzati (**user.txt** e **password.txt**, contenenti rispettivamente 4 e 6 voci), secondo il comando:

hydra -L user.txt -P password.txt -t 4 192.168.1.10 ssh

```
Session Actions Edit View Help
(kali@kali)~/Desktop/Esercizi/U2_M2_L5$
$ hydra -L user.txt -P password.txt -t 4 192.168.1.10 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics any way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 12:09:33
[DATA] max 4 tasks per 1 server, overall 4 tasks, 24 login tries (l:4/p:6), ~6 tries per task
[DATA] attacking ssh://192.168.1.10:22/
[22][ssh] host: 192.168.1.10 login: test_user password: testpass
[ERROR] all children were disabled due to too many connection errors
0 of 1 target successfully completed, 1 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
The session file ./hydra.restore was written. Type "hydra -R" to resume session.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 12:09:46
```

5.5 Sintesi della Fase 1

I risultati della Fase 1 dimostrano che:

- il servizio SSH configurato con credenziali deboli (**testpass**) risulta immediatamente compromesso quando la credenziale corretta è nota o presente in una wordlist di dimensioni contenute;
- il protocollo SSH è, per costruzione, relativamente resiliente agli attacchi a dizionario ad alto parallelismo, poiché le politiche di *rate-limiting* del demone (**MaxAuthTries**, gestione delle connessioni concorrenti) tendono a interrompere le sessioni di attacco eccessivamente aggressive, con conseguente rallentamento forzato dell'attività di auditing.


```
Session Actions Edit View Help
GNU nano 9.1 /etc/ssh/sshd_config:

# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/bin:/usr/games

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
LoginGraceTime 30s
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 6
MaxAuthTries 10
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.

[ Wrote 126 lines ]
^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify
^C Location  M-U Undo
^_ Go To Line M-E Redo
```

6. Fase 2 – Configurazione e Cracking del Servizio FTP

Per la seconda fase dell'esercizio, condotta in autonomia, è stato selezionato il servizio **FTP**, implementato tramite il demone **vsftpd**, in linea con il suggerimento fornito nella traccia dell'esercitazione.

6.1 Installazione e attivazione del servizio

Il pacchetto **vsftpd** è stato installato mediante **sudo apt install vsftpd**, quindi il servizio è stato avviato con **sudo service vsftpd start**. La verifica dello stato (**sudo service vsftpd status**) ha confermato l'effettiva attivazione del demone, riportato come **active (running)**.

```
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.3.2)...

(kali@kali)-[~]
$ sudo service vsftpd start

(kali@kali)-[~]
$ sudo service vsftpd status
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-07-17 14:12:18 CEST; 9s ago
  Invocation: fd3717b948f649b99e235a4d45ea82fa
     Docs: man:vsftpd(8)
  Process: 47507 ExecStartPre=/bin/mkdir -p /run/vsftpd/empty (code=exited, status=0/SUCCESS)
 Main PID: 47509 (vsftpd)
    Tasks: 1 (limit: 4467)
  Memory: 1.2M (peak: 2.3M)
     CPU: 9ms
  CGroup: /system.slice/vsftpd.service
          └─47509 /usr/sbin/vsftpd /etc/vsftpd.conf

Jul 17 14:12:18 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server ...
Jul 17 14:12:18 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

(kali@kali)-[~]
$
```

6.2 Test rapido di validazione

Analogamente a quanto effettuato per SSH, è stato eseguito un primo test di validazione con credenziali note, adottando in questo caso ulteriori opzioni di Hydra (**-t 1 -w 2 -I**), rispettivamente relative al numero di task paralleli, al tempo di attesa fra i tentativi e all'istruzione di ignorare eventuali file di ripristino (*restore*) di sessioni precedenti:

```
hydra -l test_user -p testpass -t 1 -w 2 -I ftp://192.168.1.10
```

```
(kali@kali):~$ hydra -l test_user -p testpass -t 1 -w 2 -i ftp://192.168.1.10
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics any way).

[WARNING] the waittime you set is low, this can result in erroneous results
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 14:28:23
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (1:1/p:1), -1 try per task
[DATA] attacking ftp://192.168.1.10:21/
[21]ftp host: 192.168.1.10 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 14:28:24

(kali@kali):~$
```

6.3 Attacco a dizionario con wordlist personalizzata

Si è quindi proceduto a un attacco a dizionario con le medesime wordlist personalizzate impiegate nella Fase 1 (24 combinazioni complessive: 4 utenti × 6 password), incrementando tuttavia il grado di parallelismo a **-t 6**, in ragione della natura più leggera del protocollo FTP rispetto a SSH:

```
hydra -L user.txt -P password.txt -t 6 -V ftp://192.168.1.10
```

L'attacco ha individuato la credenziale valida (**test_user/testpass**) al ventunesimo tentativo su ventiquattro complessivi, portando comunque a termine l'intera scansione senza errori di connessione, con esito *«1 of 1 target successfully completed, 1 valid password found»* in circa quindici secondi.

```
(kali@kali):~$ hydra -L ~/Desktop/Esercizi2/U2_U2_L5/user.txt -P ~/Desktop/Esercizi2/U2_U2_L5/password.txt -t 6 -V ftp://192.168.1.10
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics any way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 14:43:28
[DATA] max 6 tasks per 1 server, overall 6 tasks, 24 login tries (1:4/p:6), -4 tries per task
[DATA] attacking ftp://192.168.1.10:21/
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "testpass" - 1 of 24 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "password" - 2 of 24 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "123456" - 3 of 24 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "admin" - 4 of 24 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "qwerty" - 5 of 24 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "letmein" - 6 of 24 [child 5] (0/0)
[21]ftp host: 192.168.1.10 login: test_user password: testpass
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "testpass" - 7 of 24 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "password" - 8 of 24 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "123456" - 9 of 24 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "admin" - 10 of 24 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "qwerty" - 11 of 24 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "letmein" - 12 of 24 [child 5] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "testpass" - 13 of 24 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "password" - 14 of 24 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "123456" - 15 of 24 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "admin" - 16 of 24 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "qwerty" - 17 of 24 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "letmein" - 18 of 24 [child 5] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "testpass" - 19 of 24 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "password" - 20 of 24 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "123456" - 21 of 24 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "admin" - 22 of 24 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "qwerty" - 23 of 24 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "kali" - pass "letmein" - 24 of 24 [child 5] (0/0)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 14:43:43
```

Tale esito conferma quanto ipotizzato: il protocollo FTP, privo di meccanismi di *rate-limiting* nativi paragonabili a quelli di SSH nella configurazione di default, consente un grado di parallelismo sensibilmente più elevato senza compromettere la stabilità del servizio.

6.4 Attacco su larga scala con wordlist SecLists

Per verificare l'effettiva efficacia e i tempi di esecuzione su scenari più realistici, in linea con l'indicazione della traccia relativa all'impiego della suite **SecLists** (installabile con **sudo apt install seclists**), è stata condotta una campagna di attacco su scala maggiore, utilizzando la lista utenti **top-usernames-shortlist.txt** (18 voci) e la lista password

1k-most-common.txt (100 voci), per un totale di 1.800 combinazioni di credenziali, con parallelismo incrementato a -t 10:

```
hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
```

```
-P /usr/share/seclists/Passwords/Common-Credentials/1k-most-common.txt \
```

```
-t 10 -V ftp://192.168.1.10
```

```
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 14:48:42

(kali@kali)~$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P /usr/share/seclists/Passwords/Common-Credentials/1k-most-common.txt -t 10 -V ftp://192.168.1.10
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics any way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 14:50:25
[DATA] max 10 tasks per 1 server, overall 10 tasks, 1800 login tries (1:10/p:100), ~180 tries per task
[DATA] attacking ftp://192.168.1.10:21/
[ATTEMPT] target 192.168.1.10 - login "root" - pass "password" - 1 of 1800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "123456" - 2 of 1800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "root" - pass "12345678" - 3 of 1800 [child 2] (0/0)
```

La scansione, avviata alle ore 14:50:25, ha proceduto sistematicamente attraverso le combinazioni utente/password (admin, root, test_user, test, azureuser, tra gli altri), individuando la credenziale valida test_user/testpass in corrispondenza del 205° tentativo su 1.800.

```
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "richard" - 194 of 1800 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "diamond" - 195 of 1800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "yellow" - 196 of 1800 [child 8] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "bigdog" - 197 of 1800 [child 6] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "secret" - 198 of 1800 [child 9] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "asdfgh" - 199 of 1800 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "admin" - pass "sparky" - 200 of 1800 [child 7] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "password" - 201 of 1800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "123456" - 202 of 1800 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "12345678" - 203 of 1800 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "1234" - 204 of 1800 [child 5] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "testpass" - 205 of 1800 [child 8] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "qwerty" - 206 of 1800 [child 6] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test_user" - pass "12345" - 207 of 1800 [child 0] (0/0)
[21] [ftp] host: 192.168.1.10 login: test_user password: testpass
[ATTEMPT] target 192.168.1.10 - login "test" - pass "password" - 301 of 1800 [child 8] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "123456" - 302 of 1800 [child 9] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "12345678" - 303 of 1800 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "1234" - 304 of 1800 [child 7] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "testpass" - 305 of 1800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "qwerty" - 306 of 1800 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "12345" - 307 of 1800 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "dragon" - 308 of 1800 [child 5] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "pussy" - 309 of 1800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "baseball" - 310 of 1800 [child 6] (0/0)
[ATTEMPT] target 192.168.1.10 - login "test" - pass "football" - 311 of 1800 [child 8] (0/0)
```

In assenza dell'opzione -f (terminazione dell'intera scansione al primo esito positivo), Hydra ha proseguito l'analisi delle restanti combinazioni relative alle altre utenze presenti nella wordlist, portando a termine l'intera campagna — 1.800 tentativi complessivi — in circa dieci minuti, con conclusione alle ore 15:00:06 e messaggio finale «1 of 1 target successfully completed, 1 valid password found».

```
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "121212" - 1787 of 1800 [child 8] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "golfer" - 1788 of 1800 [child 7] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "cheese" - 1789 of 1800 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "princess" - 1790 of 1800 [child 2] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "martin" - 1791 of 1800 [child 5] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "chelsea" - 1792 of 1800 [child 9] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "patrick" - 1793 of 1800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "richard" - 1794 of 1800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "diamond" - 1795 of 1800 [child 3] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "yellow" - 1796 of 1800 [child 8] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "bigdog" - 1797 of 1800 [child 6] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "secret" - 1798 of 1800 [child 7] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "asdfgh" - 1799 of 1800 [child 4] (0/0)
[ATTEMPT] target 192.168.1.10 - login "azureuser" - pass "sparky" - 1800 of 1800 [child 2] (0/0)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 15:00:06
```

6.5 Sintesi della Fase 2

I risultati della Fase 2 dimostrano che:

- il servizio FTP, in configurazione di base, tollera un parallelismo di attacco sensibilmente maggiore rispetto a SSH, senza generare errori di connessione o interruzioni del servizio;
- l'impiego di wordlist realistiche e di dimensioni maggiori (come quelle fornite da SecLists), pur incrementando in modo significativo il numero di combinazioni da testare, non comporta necessariamente tempi di esecuzione proibitivi quando accompagnato da un adeguato grado di parallelismo, contrariamente a quanto osservato per il servizio SSH.

7. Analisi Comparata dei Risultati

La tabella seguente sintetizza le principali evidenze raccolte nel corso delle due fasi dell'esercitazione:

Parametro	SSH	FTP
Porta di servizio	22/TCP	21/TCP
Credenziale target	test_user / testpass	test_user / testpass
Parallelismo massimo stabile osservato	4 (con limitazioni)	10
Comportamento a -t elevato	Interruzione per errori di connessione / crash del servizio	Nessun errore rilevato
Tempo attacco su piccola wordlist (24 combinazioni)	Interrotto per errori	~15 secondi (completo)
Tempo stimato su wordlist estesa (100 password)	~1 ora (a -t 3)	~10 minuti (1.800 combinazioni, a -t 10)
Necessità di modifica configurazione	Sì (MaxAuthTries)	Sì (MaxAuthTries)

Dall'analisi comparata emerge con chiarezza come la superficie di esposizione al *brute-force* non dipenda unicamente dalla robustezza della password, bensì anche dalle caratteristiche intrinseche del protocollo e dalla presenza — o assenza — di meccanismi nativi di contenimento dei tentativi di autenticazione falliti. SSH, pur non impedendo l'individuazione di una credenziale debole, ha imposto un vincolo prestazionale rilevante all'attaccante, rallentando sensibilmente la campagna; FTP, al contrario, si è dimostrato privo di analoghe protezioni, risultando compromettibile con un'efficienza nettamente superiore.

8. Verifica di Aderenza agli Obiettivi Didattici

In relazione agli obiettivi indicati nella consegna dell'esercizio (§ 2), si riepiloga di seguito il grado di conseguimento dei risultati attesi:

Obiettivo previsto dalla consegna	Attività svolta
Configurazione di un'utenza di test	Creazione utenza <code>test_user</code> con <code>adduser</code>
Attivazione del servizio SSH	<code>sudo service ssh start</code> e verifica dello stato
Verifica della connessione SSH	Login manuale tramite client <code>ssh</code>
Comprensione della sintassi Hydra (credenziale singola)	Esecuzione con <code>-l/-p</code>
Comprensione della sintassi Hydra (dizionario)	Esecuzione con <code>-L/-P</code>
Configurazione autonoma di un secondo servizio	Installazione e avvio di <code>vsftpd</code>
Cracking del secondo servizio con Hydra	Attacchi a dizionario FTP a complessità crescente
Impiego di SecLists per wordlist realistiche	Attacco su 1.800 combinazioni
Individuazione di soluzioni per ridurre i tempi di attacco	Ottimizzazione del parallelismo (<code>-t</code>) e confronto SSH/FTP

9. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha consentito di consolidare, in un contesto pratico e controllato, le competenze relative sia alla configurazione di servizi di rete di uso comune, sia all'impiego di strumenti di *password auditing* quali Hydra, nel pieno rispetto dei principi dell'*ethical hacking*.

Le principali lezioni apprese possono essere così riassunte:

1. **La configurazione di default dei servizi non è, di per sé, sicura.** Sia SSH sia FTP, se lasciati con credenziali deboli, risultano compromettibili in tempi contenuti; la sicurezza effettiva dipende dalla combinazione di credenziali robuste e di controlli complementari.
2. **Non tutti i protocolli offrono lo stesso grado di resilienza implicita agli attacchi a dizionario.** L'esperienza condotta ha mostrato come SSH, grazie a meccanismi nativi di limitazione dei tentativi di connessione, imponga un vincolo prestazionale significativo a un attaccante, mentre FTP, privo di analoghe protezioni nella configurazione analizzata, si sia rivelato sensibilmente più esposto.
3. **Il parallelismo di un attacco a dizionario è un parametro critico, da tarare empiricamente.** Un valore eccessivo dell'opzione `-t` può causare l'interruzione della scansione per errori di connessione o, in scenari reali, il *denial of service* del sistema bersaglio; un valore troppo conservativo, di contro, rende la campagna di auditing impraticabile su larga scala per ragioni di tempo.
4. **L'uso di wordlist realistiche (SecLists) è determinante** per una valutazione di sicurezza rappresentativa delle minacce effettivamente presenti nel panorama reale, rispetto a wordlist minimali costruite ad hoc.
5. **La difesa efficace richiede un approccio stratificato**, come discusso nel capitolo 8, che integri robustezza delle credenziali, limitazione dei tentativi, cifratura delle comunicazioni, autenticazione a più fattori e monitoraggio continuo.

In conclusione, l'attività svolta ha dimostrato in modo empirico e riproducibile come la mancata applicazione di pratiche elementari di *hardening* dei servizi di rete — a partire dalla scelta di credenziali robuste — possa tradursi, in tempi estremamente ridotti (dell'ordine di pochi secondi nel caso peggiore analizzato), nella completa compromissione dell'autenticazione di un sistema. Tale evidenza rafforza l'importanza, per ogni professionista della sicurezza informatica, di adottare un approccio proattivo alla protezione dei sistemi, fondato sulla verifica periodica e controllata della robustezza dei propri meccanismi di autenticazione, quale strumento indispensabile di prevenzione rispetto a minacce analoghe condotte, in contesti reali, da attori privi delle finalità didattiche ed etiche proprie della presente esercitazione.